03 Regras de negocio, casos de uso e API

Contratos REST operacionais V1 | exemplos JSON + regras de ativacao | rev. ambientes 23/10/2026

Atores e contratos

Mesmo contrato, ambientes independentes

Ambiente	Execução / destino	Regra de integração
Desenvolvimento	Frontend local/Preview → Node/Express local → plantel-dev (Supabase Free)	JWT e recursos de DEV; IDs/dados fictícios; sem segredos SQL no navegador
Produção	Frontend Vercel Production → Node/Express Render → plantel-prod (Supabase Pro)	Mesmos endpoints e envelopes; credenciais e dados reais isolados

Mudanças de ambiente não mudam contratos REST nem regras de negócio. Toda alteração de rota/payload exige revisão conjunta do documento 03 e PRs; nunca apontar Preview para o banco de produção.

Aluno, Administrador e Superadministrador. Assinatura Free/Pro nao altera hierarquia. A API Express decide regras; o cliente nunca define usuario_id autoritativo.

Sessao confiavel

JWT valido → identidade e objetivo autorizados

↓

Criar sessao: API registra inicio_servidor e modo

↓

Pausas/fim: API valida transicoes, calcula duracao elegivel

↓

Confirmacao: registra eventos e atualiza agregados permitidos

↓

Ranking: apenas sessoes elegiveis, teto de 10h por dia

Liberacao de Pro

Aluno escolhe plano → Mercado Pago cria operacao

↓

Webhook assinado/idempotente recebido pela API

↓

API reconcilia estado com provedor e persiste pagamento

↓

Direitos_acesso atualizados transacionalmente

↓

Frontend consulta direitos pelo backend; nao libera com retorno visual

Regras por dominio

Codigo	Regra de negocio
RN-01	Cadastro: nome, email, senha, apelido e data_nascimento; confirmação de email; nao solicitar telefone/tag.
RN-02	Apelidos e nomes: normalizar, evitar duplicidade e filtrar ofensivos em portugues e ingles com revisao humana quando necessario.
RN-03	Timer: servidor e fonte do tempo; sessao manual nao entra em ranking.
RN-04	Ranking de grupo: somar apenas tempo elegivel, no maximo 10h/dia por usuario.
RN-05	Revisoes Pro: politica 1/7/30, limites de capacidade, dificuldade, folgas, atraso e retomada.
RN-06	Trial Pro: oferta apos PRIMEIRA sessao elegivel e confirmada; ativacao somente por aceite explicito no POST /api/pro/teste/ativar, com email verificado; 14 dias a partir da concessao; uma vez por conta. Nunca conceder automaticamente na conclusao da sessao.
RN-07	Pagamento: somente reconciliacao confiavel habilita Pro; repeticao de webhook nao duplica efeito.
RN-08	Participacao: grupo e mural visiveis somente aos membros autorizados; privacidade de menores.
RN-09	Privacidade: exportacao e exclusao com identificacao/registro; sem exposicao de dados sensiveis.
RN-10	RBAC: apenas superadmin altera acesso administrativo; manter auditoria.
RN-11	Indicacoes: cadastro por link pode ser registrado; concessao automatica de dias Pro BLOQUEADA ate regra antifraude e elegibilidade aprovadas, sem telefone.
RN-12	Meta coletiva: acompanhar progresso e atividade autorizada; recompensas em dias Pro BLOQUEADAS ate aprovacao expressa. Nao usar flag de interface como direito Pro.

Contratos REST — Identidade e perfil

Método	Endpoint	Acesso	Finalidade
GET	/api/me	Auth	Contexto do usuário, perfil, privacidade e entitlements
POST	/api/onboarding	Auth	Finaliza onboarding/objetivo
PATCH	/api/me/perfil	Auth	Atualiza campos permitidos
PATCH	/api/me/privacidade	Auth	Atualiza preferências
POST	/api/me/aceites	Auth	Registra aceite versionado
POST	/api/me/confirmacao-email/iniciar	Auth	Inicia reenvio de confirmação de e-mail com rate limit
POST	/api/me/confirmacao-email/confirmar	Auth	Confirma código

Contratos REST — Catalogo e estudo

Método	Endpoint	Acesso	Finalidade
GET	/api/catalogo/provas	Público/Auth	Lista publicada
GET	/api/catalogo/provas/:id	Público/Auth	Disciplinas/tópicos publicados
POST	/api/sessoes	Auth	Inicia sessão; horário do servidor
POST	/api/sessoes/:id/pausar	Auth	Registra pausa quando aplicável
POST	/api/sessoes/:id/estender	Auth	Estende bloco
POST	/api/sessoes/:id/confirmar	Auth	Confirma janela

Método	Endpoint	Acesso	Finalidade
POST	/api/sessoes/:id/encerrar	Auth	Encerra sessão
POST	/api/sessoes/manual	Auth	Registro manual fora do ranking
GET	/api/sessoes	Auth	Histórico próprio
GET	/api/hoje	Auth	Resumo de hoje, revisões e avisos
POST	/api/sessoes/:id/continuar	Auth dono	Retoma sessao pausada; o servidor valida transicao

Contratos REST — Revisoes

Método	Endpoint	Acesso	Finalidade
GET	/api/revisoes	Pro/Trial	Fila atual e prioridades
POST	/api/revisoes/:id/concluir	Pro/Trial	Autoavaliação + opcionais questões/acertos
POST	/api/revisoes/:id/reagendar	Pro/Trial	Reagenda dentro das regras
POST	/api/revisoes/:id/ignorar	Pro/Trial	Ignora com histórico
PATCH	/api/revisoes/configuracao	Auth	Espaço diário e folgas
POST	/api/revisoes/recuperacao	Pro/Trial	Aceita/ajusta plano
POST	/api/revisoes/retomada	Pro/Trial	Triagem e retomada gradual

Contratos REST — Social e ranking

Método	Endpoint	Acesso	Finalidade
POST	/api/grupos	Auth	Cria grupo
POST	/api/grupos/:id/convites	Auth membro	Gera link
POST	/api/convites/:codigo/entrar	Auth	Entrar no grupo
GET	/api/grupos/:id	Membro	Dados e mesa
POST	/api/grupos/:id/sair	Membro	Sai preservando histórico
POST	/api/grupos/:id/mural	Membro	Publica card permitido
POST	/api/mural/:id/reacoes	Membro	Reação pronta
POST	/api/grupos/:id/metas	Membro autorizado	Cria/ajusta meta coletiva
GET	/api/grupos/:id/ranking	Membro	Ranking por período

Contratos REST — Assinaturas, pagamento e operacao

Método	Endpoint	Acesso	Finalidade
POST	/api/pro/teste/ativar	Auth + e-mail confirmado	Aluno aceita oferta apos sessao elegivel; validar sessao, email e concessao unica antes de ativar
GET	/api/pro/status	Auth	Entitlements e fila guardada
GET	/api/planos	Público/Auth	Planos ativos
POST	/api/assinaturas	Auth	Cria assinatura
POST	/api/assinaturas/:id/cancelar	Auth dono	Cancela renovação
POST	/api/webhooks/mercado-pago	Gateway	Webhook idempotente
POST	/api/administracao/pagamentos/reconciliar	Admin	Conciliação controlada
GET	/api/relatorios/domingo	Auth	Resumo Free/relatório Pro
GET	/api/notificacoes	Auth	Notificações próprias
POST	/api/dados/exportacao	Auth	Solicita exportação
POST	/api/dados/exclusao	Auth + confirmação forte	Solicita exclusão
GET	/api/dados/solicitacoes/:id	Auth dono	Acompanha pedido

Contrato JSON V1: convenções de integração

Os formatos abaixo padronizam a integração e preservam os endpoints inventariados acima. A implementação deve ser validada em PR com o Documento 02 e o protótipo F0; nenhuma mudança contratual silenciosa é permitida.

Ponto	Regra operacional
Base da API	/api. Recursos autenticados usam Authorization: Bearer <JWT Supabase>; usuario_id vem do token validado, nunca do body.
Sucesso	Envelope {"dados": {...}}; em listagens, {"dados": [...], "paginacao": {"pagina":1,"limite":20,"total":0}}. Resposta 204 pode ter corpo vazio.
Erro	{"erro":{"codigo":"CODIGO_ESTAVEL","mensagem":"Texto seguro","detalhes":[],"requisicao_id":"..."}}. Nao incluir stack, token, segredo ou SQL.
Datas, IDs e quantias	IDs UUID como strings; timestamps ISO-8601 UTC; datas civis AAAA-MM-DD; valores em centavos inteiros; duracoes em segundos inteiros.
HTTP	200 leitura/alteracao, 201 criacao, 202 operacao assíncrona, 204 sem corpo; 400/401/403/404/409/422/429/5xx conforme contexto.
Idempotencia	Para inicio de sessao, assinatura e operacoes sensiveis, header Idempotency-Key (UUID), persistido no backend. Repeticao consistente nao duplica gravacao.
Campos opcionais	Omitir ou enviar null somente conforme schema da rota; JSON desconhecido deve ser rejeitado/ignorado de forma definida pelo Validator e coberto por testes.
Paginacao	GET de colecoes: pagina=1 e limite=20; teto 100; ordenar de forma deterministica; usuario e autorizacao aplicados antes da paginacao.

Matriz de formatos por rota

Tipos simplificados: UUID=string; texto=string; data=AAA-MM-DD; instante=ISO UTC; lista=[...]. Todo retorno segue o envelope de sucesso, salvo webhook (ack) e 204.

Identidade

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
GET /api/me	JWT	—	perfil, papel, objetivo, plano, privacidade, email_confirmado
POST /api/onboarding	JWT	prova_id:UUID; meta_diaria_minutos:int	objetivo_id:UUID; finalizado:true
PATCH /api/me/perfil	JWT	nome?:texto; apelido?:texto; avatar_url?:texto	perfil atualizado, campos publicos limitados
PATCH /api/me/privacidade	JWT	visibilidade_grupo?:enum; notificacoes?:bool	preferencias atualizadas
POST /api/me/aceites	JWT	tipo:enum; versao:texto; aceito:bool	aceite_id; aceito_em
POST /api/me/confirmacao-email/iniciar	JWT	—	status:enviado; proximo_reenvio_em?
POST /api/me/confirmacao-email/confirmar	JWT	token_ou_codigo:texto (se aplicável ao fluxo Auth)	confirmado:true; usar SDK Auth se confirmação direta

Catalogo

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
GET /api/catalogo/provas	publico	—	lista de id, nome, slug, status
GET /api/catalogo/provas/:id	publico	—	prova + disciplinas[] + topicos[] publicados

Sessoes

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
POST /api/sessoes	JWT	disciplina_id; topico_id?; modo; bloco_minutos?	id; status; inicio_servidor; modo
POST /api/sessoes/:id/pausar	dono	—	id; status:pausada; pausada_em
POST /api/sessoes/:id/continuar	dono	—	id; status:em_andamento; retomada_em
POST /api/sessoes/:id/estender	dono	minutos_adicionais:int	id; duracao_planejada_minutos
POST /api/sessoes/:id/encerrar	dono	—	id; status:encerrada; fim_servidor; duracao_segundos
POST /api/sessoes/:id/confirmar	dono	—	id; confirmada; elegivel_ranking; oferta_teste_pro
POST /api/sessoes/manual	JWT	disciplina_id; topico_id?; data; minutos	id; manual:true; elegivel_ranking:false
GET /api/sessoes	dono	pagina?, limite?, periodo?, disciplina_id?	sessoes[]; paginacao
GET /api/hoje	JWT	—	meta, tempo_estudado, sessoes, revisoes_resumo, pro

Revisoes

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
GET /api/revisoes	Pro/Trial	status?, pagina?, limite?	revisoes[]; prioridades; paginacao
POST /api/revisoes/:id/concluir	dono + Pro	dificuldade:enum; questoes?, acertos?	revisao; proxima_previsao; historico
POST /api/revisoes/:id/reagendar	dono + Pro	data_proposta:data	revisao; data_prevista; criterio
POST /api/revisoes/:id/ignorar	dono + Pro	motivo?:enum	revisao; status:ignorada
PATCH /api/revisoes/configuracao	JWT	espaco_diario_min; dias_folga[]	configuracao atualizada
POST /api/revisoes/recuperacao	Pro/Trial	acao:aceitar|ajustar|ignorar; parametros?	plano_id; status
POST /api/revisoes/retomada	Pro/Trial	preferencias?:objeto	plano_retomada; previsao

Social

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
POST /api/grupos	JWT	nome; tipo	id; nome; criado_por
POST /api/grupos/:id/convites	membro autorizado	limite_usos?; expira_em?	codigo; url; expira_em
POST /api/convites/:codigo/entrar	JWT	—	grupo_id; status_membro
GET /api/grupos/:id	membro	—	grupo; membros_publicos[]; mesa_resumo
POST /api/grupos/:id/sair	membro	—	grupo_id; status_membro:inativo
POST /api/grupos/:id/mural	membro	tipo; referencia_id	post_id; criado_em; publicado_por
POST /api/mural/:id/reacoes	membro	tipo:enum_aprovado	reacao_id; tipo
POST /api/grupos/:id/metas	membro autorizado	meta_minutos; semana_ref	meta_id; progresso; recompensa_bloqueada:true
GET /api/grupos/:id/ranking	membro	periodo:semana|dia	posicoes[]; periodo; teto_diario_minutos:600

Comercial

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
GET /api/pro/status	JWT	—	plano; teste_elegivel; oferta_disponivel; direitos[]
POST /api/pro/teste/ativar	JWT + email confirmado	sessao_id:UUID; aceite:true	inicio; fim; status:ativo; direitos
GET /api/planos	publico	—	planos[] com moeda, preco_centavos, periodicidade
POST /api/assinaturas	JWT	plano_id; metodo_pagamento	assinatura_id; status; checkout_url?
POST /api/assinaturas/:id/cancelar	dono	motivo?:enum	assinatura_id; status; fim_periodo

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
POST /api/webhooks/mercado-pago	gateway validado	payload bruto assinado	ack:recebido; sem detalhes sensiveis
POST /api/administracao/pagamentos/reconciliar	admin autorizado	referencia:UUID; justificativa	resultado; auditado_em

Operacao

Método / rota	Acesso	Entrada (JSON ou query)	Dados na resposta
GET /api/relatorios/domingo	JWT	semana?:data	semana; resumo; tipo:free|pro
GET /api/notificacoes	JWT	pagina?, limite?	notificacoes[]; paginacao
POST /api/dados/exportacao	JWT	confirmacao?:bool	solicitacao_id; status:recebida
POST /api/dados/exclusao	JWT + confirmacao forte	confirmacao:true	solicitacao_id; status:recebida
GET /api/dados/solicitacoes/:id	dono	—	solicitacao_id; status; datas

Exemplos canônicos de entrada e saída

Os UUIDs e datas são fictícios. Valores e enumerações finais devem ser validados por schema da Issue, nunca inferidos pelo cliente. O envelope dados/erro, os identificadores e o fluxo de trial são regras de integração.

A. GET /api/me

```
ENVIO:   GET /api/me  (Bearer JWT)
RETORNO:   {"dados":
{"usuario_id":"<uuid>","apelido":"aluno_01","papel":"aluno","email_confirmado":true,"plano":"free","objetivo":
{"prova_id":"<uuid>"}}}
```

B. POST /api/sessoes

```
ENVIO:   {"disciplina_id":"<uuid>","topico_id":"<uuid>","modo":"livre"}
RETORNO:   {"dados":{"id":"<uuid>","status":"em_andamento","inicio_servidor":"2026-10-23T12:00:00Z"}}
```

O backend registra inicio_servidor; nao aceitar hora/duracao informadas como verdade pelo navegador.

C. POST /api/sessoes/:id/confirmar

```
ENVIO:   POST /api/sessoes/<uuid>/confirmar  (body vazio)
RETORNO:   {"dados":{"id":"<uuid>","confirmada":true,"elegivel_ranking":true,"oferta_teste_pro":
{"disponivel":true,"sessao_id":"<uuid>"}}}
```

A oferta e uma possibilidade; este retorno NAO ativa o teste. Sessao manual nao gera elegibilidade de ranking.

D. GET /api/pro/status

```
ENVIO:   GET /api/pro/status  (Bearer JWT)
RETORNO:   {"dados":{"plano":"free","teste_elegivel":true,"oferta_disponivel":true,"teste_ja_utilizado":false,"direitos":
[]}}
```

E. POST /api/pro/teste/ativar

```
ENVIO:   {"sessao_id":"<uuid>","aceite":true}
RETORNO:   {"dados":{"status":"ativo","inicio":"2026-10-23T12:20:00Z","fim":"2026-11-06T12:20:00Z","dias":14,"direitos":
["revisoes_pro"]}}
```

Validar JWT, email confirmado, sessao elegivel de propriedade do aluno e UNIQUE(usuario_id) em testes_pro; conceder direito Pro de modo transacional/idempotente.

F. GET /api/revisoes

```
ENVIO:   GET /api/revisoes?status=pendente&pagina=1&limite=20
RETORNO:   {"dados":[{"id":"<uuid>","topico_id":"<uuid>","estagio":1,"prevista_em":"2026-10-
24","status":"pendente"}],"paginacao":{"pagina":1,"limite":20,"total":1}}
```

G. POST /api/assinaturas

```
ENVIO:   {"plano_id":"<uuid>","metodo_pagamento":"cartao"}
RETORNO:   {"dados":{"assinatura_id":"<uuid>","status":"pendente","checkout_url":"https://<gateway>"}}
```

Checkout URL ilustrativa; somente webhook reconciliado altera direitos_acesso. Nao presumir Pix como recorrente automatico.

H. POST /api/grupos/:id/metas

```
ENVIO:   {"meta_minutos":1200,"semana_ref":"2026-10-19"}
RETORNO:   {"dados":{"meta_id":"<uuid>","progresso_minutos":0,"recompensa_bloqueada":true}}
```

O progresso coletivo pode ser contabilizado; conceder dias Pro depende de regra de recompensa aprovada e separada.

I. Erro de autorizacao (padrao)

```
ENVIO:   PATCH /api/me/perfil  (campo proibido)
RETORNO:   {"erro":{"codigo":"ACESSO_NEGADO","mensagem":"Operacao nao permitida","detalhes":[],"requisicao_id":"<id>"}}
```

Trial Pro: maquina de estados e disparo exato

Etapa	Condição	Ação do backend	Ação do frontend
1. Primeiro estudo	Sessão elegível encerrada E confirmada; aluno autenticado	Registra elegibilidade; NAO cria testes_pro e NAO libera Pro	Mostra oferta de 14 dias; informa condições
2. Aceite explícito	Aluno aceita oferta; email verificado; nunca recebeu trial	POST /api/pro/teste/ativar valida sessao_id e ownership; transação testa UNIQUE; grava testes_pro + direitos_acesso	Exibe carregamento e, após retorno, consulta /api/pro/status
3. Vigência	início = momento da concessão; duração = 14 dias corridos	Usar relógio do servidor, expiração precisa, sem telefone	Mostrar período restante; não conceder localmente
4. Recusa ou não ação	Aluno fecha oferta	Sem concessão; poderá receber oferta novamente conforme UI aprovada	Permite estudar normalmente
5. Expiração	Tempo esgotado sem assinatura Pro ativa	Revoga direitos; preserva fila e histórico de revisões	Mostra revisões guardadas e benefícios Free
6. Tentativa repetida	Trial ja existente ou chamada concorrente	Devolver estado atual ou erro 409 seguro; jamais segunda concessão	Atualiza estado sem duplicar benefícios

Indicações e metas coletivas: política de recompensa

Há regras de recompensa da especificação original que dependiam de confirmação por telefone; esse requisito foi REMOVIDO por decisão posterior. Portanto, NÃO existe uma condição substituta aprovada para liberar dias Pro automaticamente.

O que pode executar agora	O que permanece bloqueado	Desbloqueio exige
Criar/usar convite de grupo; registrar progresso da meta coletiva e suas sessões elegíveis	Somar automaticamente dias Pro em direitos_acesso ou acionar um endpoint de concessão	Decisão expressa sobre elegibilidade, antiabuso, limites, reversão e auditoria
Registrar indicação apenas se a Issue específica aprovar coleta mínima e privacidade	Concessão automática por cadastro, sessão, convite ou pagamento	Política de indicação sem telefone + testes negativos e prevenção de múltiplas concessões

Enquanto a regra não for aprovada: PL-061/PL-063 têm implementação parcial/condicionada. Não implementar rotina de recompensa, não adicionar endpoint para bonificação e não aceitar campo recompensa_dias como autorização para conceder Pro. Registrar dependência bloqueante nas Issues; UX não promete dias Pro.

Autorização e critérios mínimos de aceite

Cenário	Resultado obrigatório
POST trial sem email confirmado / sem sessão elegível / sessão de outro aluno	Negar 403/422 conforme motivo sem expor identidade alheia; não gravar entitlement
POST trial repetido / concorrente	No máximo 1 registro por usuario_id; 1 período de direitos; status idempotente
Concluir sessão sem aceitar oferta	Nunca criar testes_pro; status continua Free

Cenário	Resultado obrigatório
Webhook duplicado / fora de ordem	Idempotência via gateway_event_id e conciliação; sem Pro indevido
Aluno Free consulta revisões Pro	Exibir apenas resumo permitido e fila preservada; operação de concluir bloqueada
Mensagem de erro / falha técnica	Formato padronizado, sem stack, segredo ou dados pessoais de terceiros
Atualização de meta coletiva	Não conceder dias Pro sem autorização de regra desbloqueada

Antes da implementação, backend e frontend devem gerar schemas compartilhados ou OpenAPI a partir deste contrato, revisar exemplos com o modelo de dados do Documento 02 e registrar a aprovação na Issue/PR. Qualquer mudança exige versão e revisão cruzada; o Codex não decide sozinho.

Resposta, autorizacao e erros

- Controller recebe req/res/next e chama Service; Service faz validacao e autorizacao; Model acessa o banco via queries parametrizadas.
- Erros esperados usam AppError com codigo/status; middleware de erro padroniza respostas sem expor stack.
- Listagens paginadas, indices adequados e quotas de rate limit.
- Definir idempotency keys para criacao de pagamento, sessoes e eventos sensiveis.
- Os contratos JSON e as regras de trial desta versao são a referencia operacional V1. Mudancas em campos/status requerem revisao do contrato, do prototipo F0 e aprovação na Issue/PR antes da implementacao. Confirmacao de e-mail segue Supabase Auth; rota proxy da API so se tecnicamente necessaria e aprovada.